

CompTIA Security+ Exam SY0-701

Lesson 9



Evaluate Network Security Capabilities

Lesson 9

Topic 9A

Network Security Baselines

Benchmarks and Secure Configuration Guides (1 of 2)

- Secure baseline
 - Collection of standard configurations and settings for operating systems, network devices, software, cloud instances, patching and updates, access controls, logging, monitoring, password policies, encryption, endpoint protection, and many others
- Center for Internet Security (CIS)
- Security Technical Implementation Guides (STIGs)
- Vendor provided guidance

Benchmarks and Secure Configuration Guides (2 of 2)

- Configuration management
 - Help manage, deploy, and measure compliance with established secure baselines
 - Puppet
 - Chef
 - Ansible
- Security Content Automation Protocol (SCAP)
 - OpenSCAP
 - CIS-CAT Pro
 - SCAP Compliance Checker (SCC)

Switches and Routers

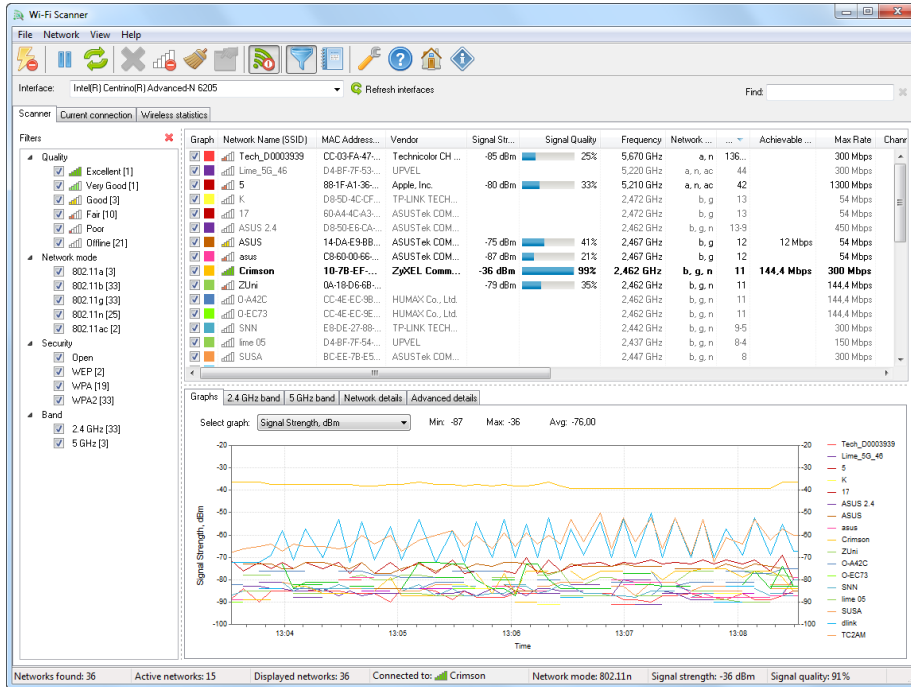
- Examples of changes designed to improve security:
- Change Default Credentials
- Disable Unnecessary
- Use Secure Management Protocols
- Implement Access Control Lists (ACLs)
- Enable Logging and Monitoring
- Configure Port Security
- Strong Password
- Physically Secure Equipment

Server Hardware and Operating Systems

- Examples of changes designed to improve security:
 - Change Default Credentials
 - Disable Unnecessary Services
 - Apply Software Security Patches and Updates Regularly
 - Least Privilege Principle
 - Use Firewalls and Intrusion Detection Systems (IDS)
 - Secure Configuration using CIS or STIG baselines
 - Strong Access Controls
 - Enable Logging and Monitoring
 - Use Antivirus and Antimalware Solutions
 - Physical Security of server equipment racks, server rooms, and datacenters

Wireless Network Installation Considerations

- Wireless Access Point (WAP) Placement
- Site Surveys and Heat Maps



Example output from Lizard System's Wi-Fi Scanner tool. (Screenshot courtesy of Lizard Systems.)

Wireless Encryption

- Open
- WEP
- WPS
- WPA & WPA2
- WPA3
 - Device Provisioning Protocol (DPP)
a.k.a. “Easy Connect” to replace WPS
 - Simultaneous Authentication of Equals (SAE)
 - Enhanced Open

Personalize settings for each band or enable Smart Connect to configure the same settings for all bands.

The screenshot displays the wireless settings for a TP-Link SOHO access point, organized into two sections for the 2.4GHz and 5GHz bands. At the top, there are global settings: 'OFDMA' is checked and set to 'Enable', and 'Smart Connect' is unchecked. The 2.4GHz section is currently active, indicated by a blue checkmark and the label 'Sharing Network'. It shows settings for Network Name (SSID) as 'TP-Link_22DD', Security as 'WPA/WPA2-Personal', Version as 'WPA2-PSK', Encryption as 'AES', Password as 'tplinkpassword', Transmit Power as 'High', Channel Width as 'Auto', Channel as 'Auto', and Mode as '802.11b/g/n mixed'. A 'Hide SSID' checkbox is also present. The 5GHz section is shown below with similar settings: Network Name (SSID) as 'TP-Link_22DD_5G', Security as 'WPA2/WPA3-Personal', Version as 'WPA3-SAE', Password as 'tplinkpassword', Transmit Power as 'High', Channel Width as 'Auto', Channel as 'Auto', and Mode as '802.11ax only'. A 'Hide SSID' checkbox is also present.

Setting	2.4GHz	5GHz
OFDMA	Enable	Enable
Smart Connect	Disable	Disable
2.4GHz	Enable	Disable
Network Name (SSID)	TP-Link_22DD	TP-Link_22DD_5G
Security	WPA/WPA2-Personal	WPA2/WPA3-Personal
Version	WPA2-PSK	WPA3-SAE
Encryption	AES	
Password	tplinkpassword	tplinkpassword
Transmit Power	High	High
Channel Width	Auto	Auto
Channel	Auto	Auto
Mode	802.11b/g/n mixed	802.11ax only
Hide SSID	Unchecked	Unchecked

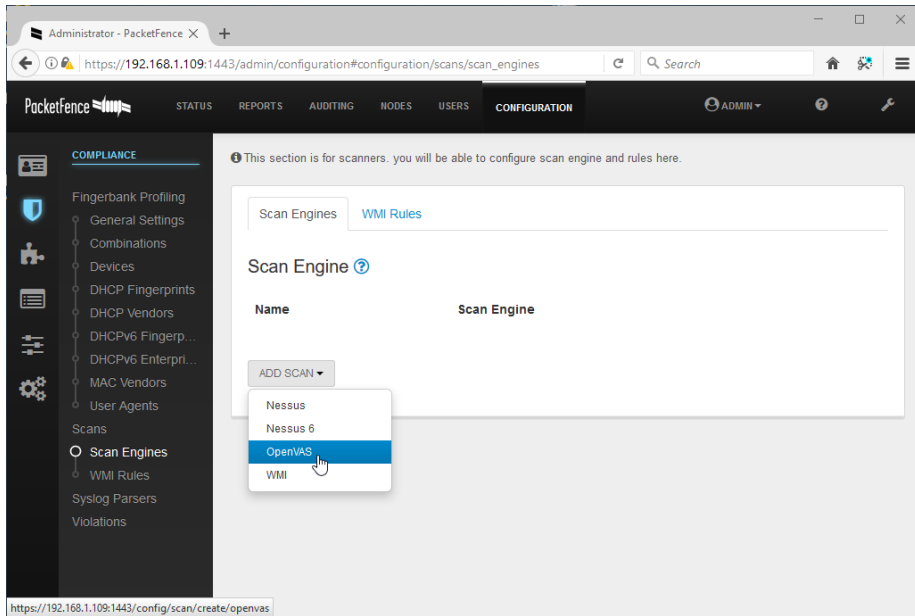
Configuring a TP-LINK SOHO access point with wireless encryption and authentication settings. In this example, the 2.4 GHz band allows legacy connections with WPA2-Personal security, while the 5 GHz network is for 802.11ax (Wi-Fi 6) capable devices using WPA3-SAE authentication. (Screenshot used with permission from TP-Link Technologies.)

Wi-Fi Authentication Methods

- WPA2 Pre-Shared Key Authentication
- WPA3 Personal Authentication
- WPA2/WPA3-Enterprise
 - RADIUS
 - EAP

Network Access Control

- Authenticates users/devices before allowing them access to the network
- Agent versus agentless



PacketFence supports the use of several scanning techniques, including vulnerability scanners, such as Nessus and OpenVAS, Windows Management Instrumentation (WMI) queries, and log parsers. (Screenshot used with permission from packetfence.org.)

Review Activity: Network Security Baselines

- Benchmarks and Secure Configuration Guides
- Wireless Network Installation Considerations
- Wireless Encryption
- Wi-Fi Authentication Methods
- Network Access Control

Lab Activity

- Assisted Lab: Understanding Security Baselines

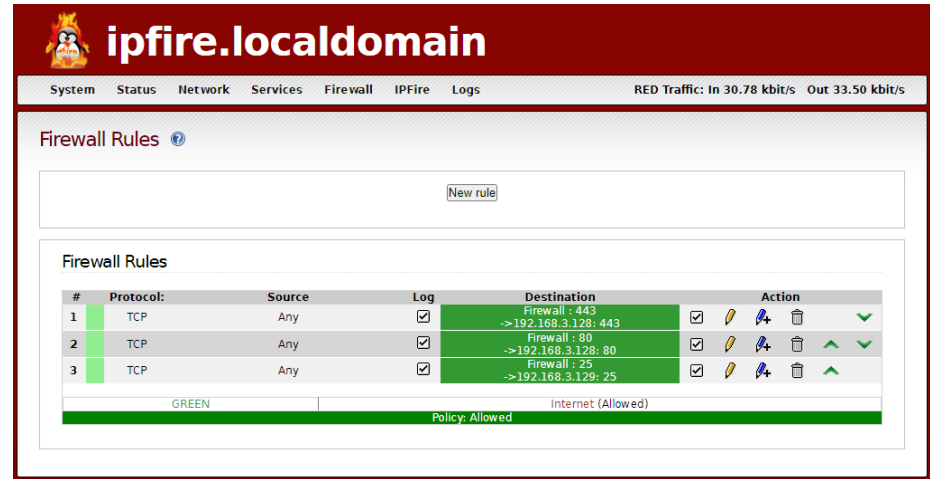
Lesson 9

Topic 9B

Network Security Capability Enhancement

Access Control Lists

- ACL
 - List of permissions associated with a network device, such as a router or a switch, that controls traffic at a network interface level
- Firewall Rule
 - Dictates how inbound or outbound network traffic for specific IP addresses, IP ranges, or network interfaces
- Screened Subnet
 - A neutral zone, separating public-facing servers from sensitive internal network resources



The screenshot displays the IPFire web interface for configuring Firewall Rules. The top navigation bar includes links for System, Status, Network, Services, Firewall, IPFire, and Logs. The current page is titled "Firewall Rules" and shows a table of configured rules. A "New rule" button is visible at the top right of the rules section.

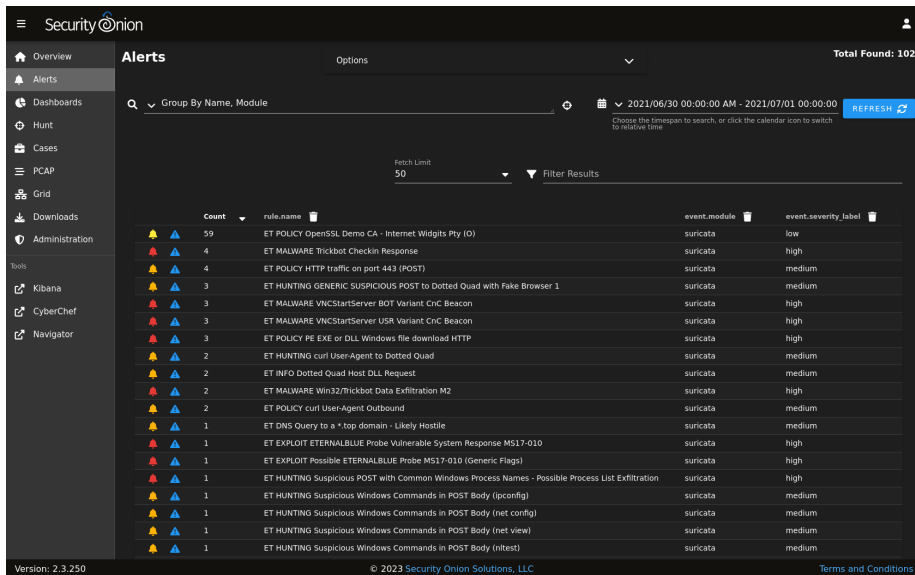
#	Protocol	Source	Log	Destination	Action
1	TCP	Any	☒	Firewall : 443 ->192.168.3.128: 443	☒
2	TCP	Any	☒	Firewall : 80 ->192.168.3.128: 80	☒
3	TCP	Any	☒	Firewall : 25 ->192.168.3.129: 25	☒

At the bottom of the table, there is a status bar showing "GREEN" and "Policy: Allowed".

Sample firewall rules configured on IPFire. This ruleset allows any HTTP, HTTPS, or SMTP traffic to specific internal addresses. (Screenshot used with permission from IPFire)

Intrusion Detection and Prevention Systems

- Host-based
- Network-based
- Both look for suspicious patterns or activities that could indicate a network or system intrusion
- They differ in their responses to perceived threats
- Snort
- Suricata
- OSSEC



The screenshot shows the Security Onion Alerts dashboard. The interface includes a sidebar with navigation options like Overview, Alerts, Dashboards, Hunt, Cases, PCAP, Grid, Downloads, and Administration. The main area displays a table of alerts with columns for Count, rule.name, event.module, and event.severity_label. The table lists various alerts, including ET POLICY OpenSSL Demo CA, ET MALWARE Trickbot Checkin Response, ET POLICY HTTP traffic on port 443 (POST), ET HUNTING GENERIC SUSPICIOUS POST to Dotted Quad with Fake Browser 1, ET MALWARE VNCStartServer BOT Variant CnC Beacon, ET MALWARE VNCStartServer USB Variant CnC Beacon, ET POLICY PE EXE or DLL Windows file download HTTP, ET HUNTING curl User-Agent to Dotted Quad, ET INFO Dotted Quad Host DLL Request, ET MALWARE Win32/Trickbot Data Exfiltration M2, ET POLICY curl User-Agent Outbound, ET DNS Query to a *top domain - Likely Hostile, ET EXPLOIT ETERNALBLUE Probe Vulnerable System Response MS17-010, ET EXPLOIT Possible ETERNALBLUE Probe MS17-010 (Generic Flags), ET HUNTING Suspicious POST with Common Windows Process Names - Possible Process List Exfiltration, ET HUNTING Suspicious Windows Commands in POST Body (pcconfig), ET HUNTING Suspicious Windows Commands in POST Body (net config), ET HUNTING Suspicious Windows Commands in POST Body (net view), and ET HUNTING Suspicious Windows Commands in POST Body (nbtstat).

Count	rule.name	event.module	event.severity_label
59	ET POLICY OpenSSL Demo CA - Internet Widgits Pty (C)	suricata	low
4	ET MALWARE Trickbot Checkin Response	suricata	high
4	ET POLICY HTTP traffic on port 443 (POST)	suricata	medium
3	ET HUNTING GENERIC SUSPICIOUS POST to Dotted Quad with Fake Browser 1	suricata	medium
3	ET MALWARE VNCStartServer BOT Variant CnC Beacon	suricata	high
3	ET MALWARE VNCStartServer USB Variant CnC Beacon	suricata	high
3	ET POLICY PE EXE or DLL Windows file download HTTP	suricata	high
2	ET HUNTING curl User-Agent to Dotted Quad	suricata	medium
2	ET INFO Dotted Quad Host DLL Request	suricata	medium
2	ET MALWARE Win32/Trickbot Data Exfiltration M2	suricata	high
2	ET POLICY curl User-Agent Outbound	suricata	medium
1	ET DNS Query to a *top domain - Likely Hostile	suricata	medium
1	ET EXPLOIT ETERNALBLUE Probe Vulnerable System Response MS17-010	suricata	high
1	ET EXPLOIT Possible ETERNALBLUE Probe MS17-010 (Generic Flags)	suricata	high
1	ET HUNTING Suspicious POST with Common Windows Process Names - Possible Process List Exfiltration	suricata	high
1	ET HUNTING Suspicious Windows Commands in POST Body (pcconfig)	suricata	medium
1	ET HUNTING Suspicious Windows Commands in POST Body (net config)	suricata	medium
1	ET HUNTING Suspicious Windows Commands in POST Body (net view)	suricata	medium
1	ET HUNTING Suspicious Windows Commands in POST Body (nbtstat)	suricata	medium

The Security Onion Alerts dashboard displaying several alerts captured using the Emerging Threats (ET) ruleset and Suricata. (Screenshot used with permission from Security Onion.)

IDS and IPS Detection Methods

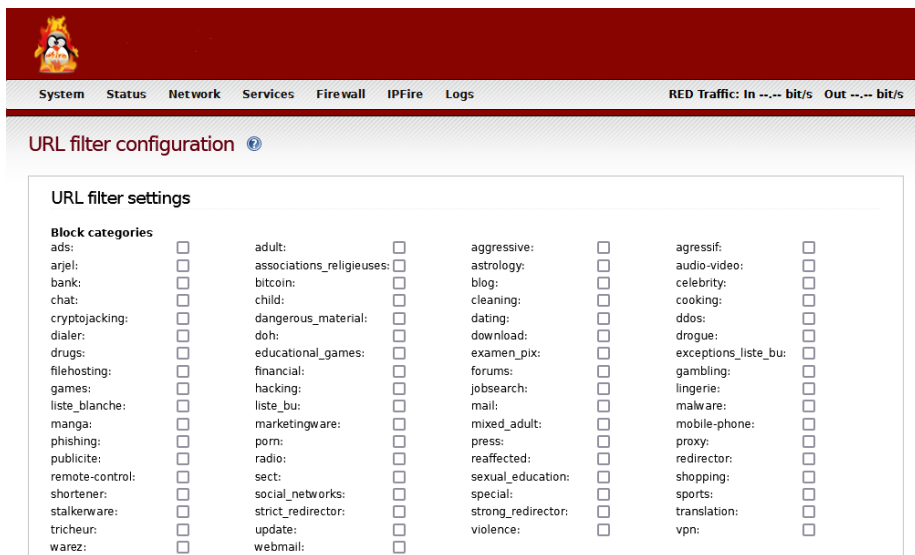
- Signature-Based Detection
- Anomaly-based detection
- Trend Analysis
- Behavioral-based detection
 - Network Behavior and Anomaly Detection (NBAD)
 - User and Entity Behavior Analytics (UEBA)

```
GNU nano 2.5.3 File: downloaded.rules
# ----- Begin ET-emerging-activex Rules Category ----- #
# -- Begin GID:1 Based Rules -- #
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Internet Explorer Plugin.ocx Heap Overfl1
alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX winhlp32 ActiveX control attack - phase 1$
alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX winhlp32 ActiveX control attack - phase 2$
alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX winhlp32 ActiveX control attack - phase 3$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX MciWndx ActiveX Control"; flow:from_serv$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX COM Object Instantiation Memory Corrupti$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Danim.dll and Dxtmsft.dll COM Objects"; $
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX JuniperSetup Control Buffer Overflow"; f$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Wmm2fxa.dll COM Object Instantiation Mem$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Multimedia Controls - ActiveX $
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Multimedia Controls - ActiveX $
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft WMIScriptUtils.WMIObjectBroker$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft VsmIDE.DTE object call CSLID";$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft DEXplore.AppObj.8.0 object cal$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft VisualStudio.DTE.8.0 object ca$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Microsoft.DbgClr.DTE.8.0 objec$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft VsaIDE.DTE object call CSLID";$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Business Object Factory object$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Outlook Data Object object cal$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Outlook.Application object cal$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX ACTIVEX Possible Microsoft IE Install En$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Possible Microsoft IE Install Engine Ins$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Possible Microsoft IE Shell.Application $
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX ACTIVEX Possible Microsoft IE Shell.Apple$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX NCTAudioFile2 ActiveX SetFormatLikeSample$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Possible Microsoft Internet Explorer ADOS$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Sony ImageStation (SonyISUpload.cab 1.0.$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Citrix Presentation Server Client Wfica.$
```

Read 27185 lines (Warning: No write permission)

Short rules file supplied by the open-source Emerging Threats community feed.

Web Filtering



Web filter content categories using the IPFire open-source firewall. (Screenshot used with permission from IPFire.)

- Block users from accessing malicious or inappropriate websites
- Enforce compliance with acceptable use
- Block malware
- Protection from phishing attacks
- Agent-Based Filtering
- Centralized Web Filtering
- URL Scanning
- Content Categorization
- Block Rules
- Reputation-Based Filtering
- Decrypting and inspecting HTTPS traffic

Review Activity: Network Security Capability Enhancement

- Access Control Lists
- Intrusion Detection and Prevention Systems
- IDS and IPS Detection Methods
- Web Filtering

Lab Activity

- Applied Lab: Implementing a Firewall

CompTIA Security+ Exam SY0-701

Lesson 9



Summary